

PERTEMUAN KE-10

Kebijakan Keamanan Informasi



Ahmad Fahrudi Setiawan

Dr. med S.Kom MT. MH.

MATAKULIAH

KEAMANAN INFORMASI

S1 TEKNIK INFORMATIKA
ITN MALANG



Ahmad Fahrudi Setiawan

Dr. med, S.Kom. MT. MH.

PERTEMUAN KE-10

Kebijakan Keamanan Informasi

In the **digital era**, data breaches are not a **matter** of possibility, but of timing—unless security policies are implemented with discipline....

Di era **digital**, kebocoran data bukan soal **kemungkinan**, tapi soal kapan—kecuali kebijakan keamanan diterapkan dengan disiplin....



Ahmad Fahrudi Setiawan

Dr. med., S.Kom., MT., MH.



Kebijakan Keamanan Informasi **| Pengertian, Tujuan,** **Jenis, dan contoh**

1. Definisi, makna



Kebijakan keamanan informasi adalah seperangkat aturan, pedoman, dan prosedur yang dirancang untuk mengatur bagaimana informasi dikelola dan dilindungi dalam suatu organisasi. Kebijakan ini mencakup seluruh aspek pengamanan data, baik dalam bentuk digital maupun fisik, agar tetap aman dari ancaman internal maupun eksternal.

Kebijakan ini biasanya menjadi bagian dari sistem manajemen keamanan informasi seperti ISO melalui standar ISO/IEC 27001.

2. Tujuan Kebijakan Keamanan Informasi



- **Melindungi Kerahasiaan (Confidentiality):** Menjaga agar informasi hanya dapat diakses oleh pihak yang berwenang.
- **Menjamin Integritas (Integrity):** Memastikan bahwa data tetap akurat, konsisten, dan tidak dapat diubah oleh pihak yang tidak berwenang.
- **Meningkatkan Ketersediaan (Availability):** Memastikan informasi dan sistem tersedia saat dibutuhkan.
- **Mencegah Ancaman Keamanan:** Melindungi organisasi dari serangan siber, peretasan, malware, dan ancaman lainnya.
- **Mematuhi Regulasi dan Standar:** Memastikan organisasi mematuhi peraturan seperti GDPR, ISO 27001, dan UU Perlindungan Data Pribadi.

Prinsip Dasar Keamanan Informasi

CIA Triad:

1. Confidentiality (Kerahasiaan)
2. Integrity (Integritas)
3. Availability (Ketersediaan)

Tambahan!

1. **Authentication** → *Autentikasi*

Proses untuk memastikan bahwa seseorang atau sistem benar-benar adalah pihak yang diklaim (misalnya login dengan password, sidik jari, atau OTP).

2. **Authorization** → *Otorisasi*

Proses untuk menentukan hak akses setelah identitas terverifikasi (misalnya apakah pengguna boleh mengakses file tertentu atau tidak).

3. **Non-repudiation** → *Nirpenyangkalan* (atau *anti-penyangkalan*)

Jaminan bahwa seseorang tidak bisa menyangkal telah melakukan suatu tindakan (misalnya dalam transaksi digital menggunakan tanda tangan digital).

3. Fungsi Utama Kebijakan Keamanan Informasi



1. Melindungi Aset Informasi

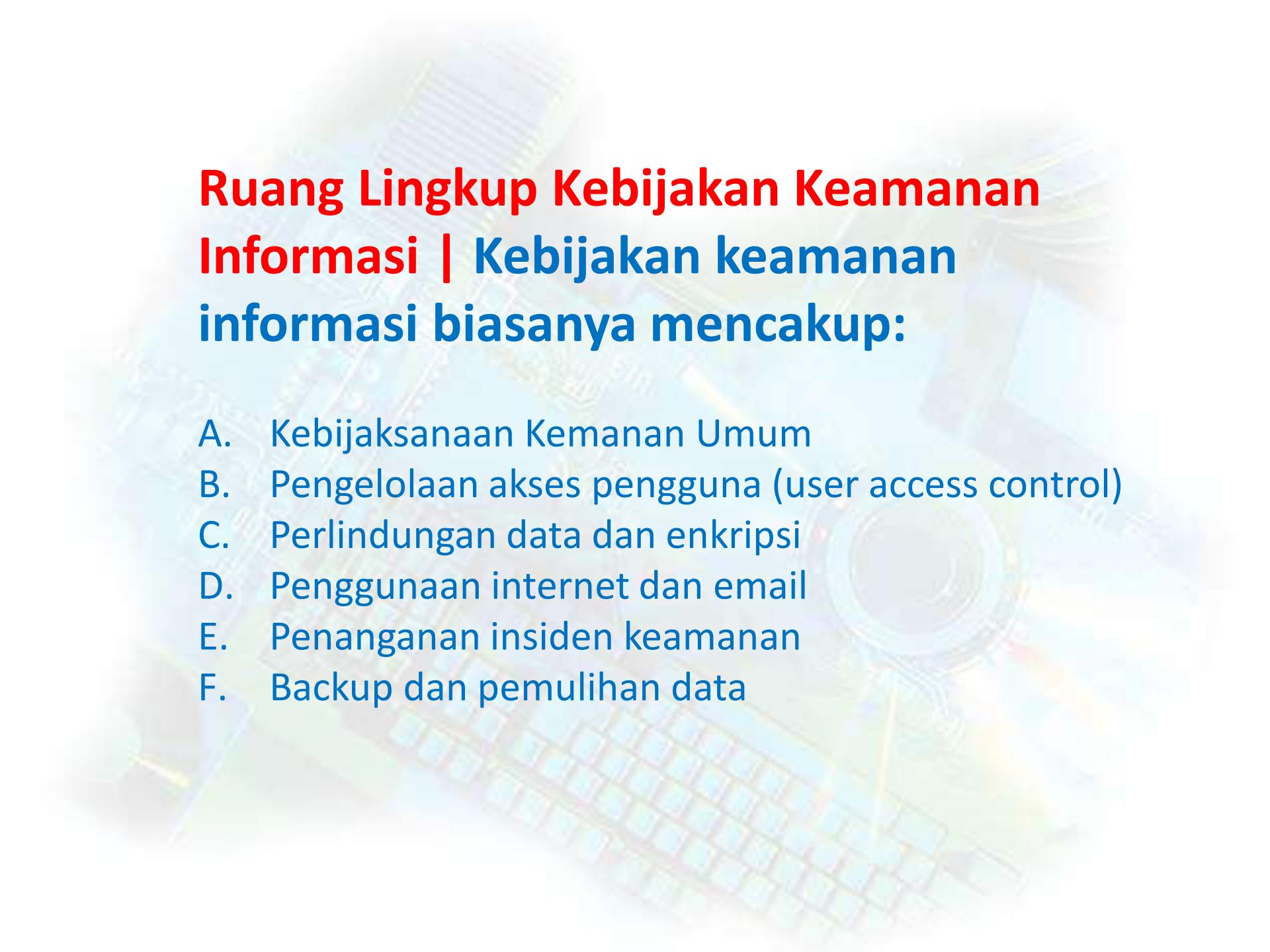
Kebijakan ini memastikan bahwa semua aset informasi seperti data pelanggan, dokumen perusahaan, dan sistem TI terlindungi dari akses tidak sah, pencurian, atau kerusakan.

2. Mengurangi Risiko Kebocoran Data

Dengan adanya aturan yang jelas, organisasi dapat meminimalkan risiko kebocoran data akibat kelalaian manusia, serangan siber, atau kesalahan sistem.

3. Menjadi Pedoman bagi Seluruh Pengguna Sistem

Kebijakan ini memberikan panduan bagi karyawan, manajemen, dan pihak terkait dalam menggunakan sistem informasi secara aman dan bertanggung jawab.



Ruang Lingkup Kebijakan Keamanan Informasi | Kebijakan keamanan informasi biasanya mencakup:

- A. Kebijaksanaan Keamanan Umum
- B. Pengelolaan akses pengguna (user access control)
- C. Perlindungan data dan enkripsi
- D. Penggunaan internet dan email
- E. Penanganan insiden keamanan
- F. Backup dan pemulihan data

A. Kebijakan Keamanan Umum (General Security Policy)

Kebijakan Keamanan Informasi

- Mengabaikan apakah perusahaan mengikuti strategi manajemen risiko kepatuhan tolak ukur maupun tidak. Suatu kebijakan yang menerapkan kebijakan keamanannya dengan pendekatan yang bertahap. figur 9.3 mengilustrasikan 5 fase implementasi kebijakan keamanan.
- Fase 1. Inisiasi proyek : tim yang menyusun kebijakan keamanan yang din bentuk dan suatu komite akan mencangkup manajer dari wilayah dimana kebijakan akan diterapkan

BAGAIMANA CARA
MEMBUAT
KEBIJAKAN
KEAMANAN IT
YANG BAIK ?



i-3.co.id/blog

Dokumen yang menguraikan prinsip dasar keamanan informasi dalam organisasi. Biasanya mencakup tujuan, cakupan, serta peran dan tanggung jawab.

Contoh:

1. Setiap karyawan harus menggunakan kata sandi yang kuat dan mengubahnya secara berkala.
2. Hanya karyawan dengan izin tertentu yang boleh mengakses data sensitif.

B. Kebijakan Pengelolaan Akses (Access Control Policy)

Mengatur siapa yang dapat mengakses informasi dan sistem IT dalam organisasi.



Contoh:

Pengguna harus memiliki autentikasi dua faktor (2FA) untuk mengakses sistem perusahaan. Hak akses karyawan harus dibatasi berdasarkan jabatan dan tanggung jawab mereka.



C. Kebijakan Penggunaan Perangkat (Acceptable Use Policy - AUP)

Menjelaskan bagaimana perangkat keras dan perangkat lunak organisasi boleh digunakan.

Contoh:

1. Dilarang mengunduh dan instal perangkat lunak yang tidak resmi pada komputer kantor.
2. Penggunaan email perusahaan hanya untuk keperluan bisnis, bukan pribadi.

C. Kebijakan Manajemen Kata Sandi (Password Management Policy)

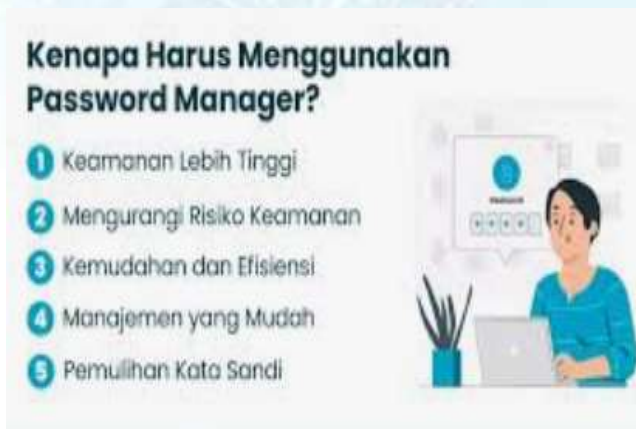
Menentukan standar dalam pembuatan dan penggunaan kata sandi.



Contoh:

Kata sandi harus terdiri dari minimal 12 karakter dan mengandung huruf besar, huruf kecil, angka, serta simbol.

Pengguna harus mengganti kata sandi setiap 90 hari.



E. Kebijakan Keamanan Data (Data Security Policy)

Mengatur cara data dikumpulkan, disimpan, dan diproses untuk menjaga keamanannya.

Contoh:

1. Data pelanggan harus dienkripsi sebelum dikirimkan melalui internet.
2. Data lama yang tidak digunakan harus dihapus atau dimusnahkan dengan aman.

D. Kebijakan Keamanan Jaringan (Network Security Policy)

Menjelaskan bagaimana jaringan organisasi harus dilindungi dari ancaman siber.



Contoh:

Firewall dan sistem deteksi intrusi harus diaktifkan di semua server perusahaan. Dilarang menggunakan jaringan WiFi publik untuk mengakses sistem perusahaan tanpa VPN.

G. Kebijakan Keamanan BYOD (Bring Your Own Device Policy)

Mengatur penggunaan perangkat pribadi untuk mengakses sistem perusahaan.

Contoh:

1. Perangkat pribadi yang digunakan untuk bekerja harus memiliki antivirus yang selalu diperbarui.
2. Data perusahaan yang disimpan di perangkat pribadi harus dienkripsi.



E. Kebijakan Pemulihan Bencana (Disaster Recovery Policy)



Menjelaskan bagaimana organisasi harus menangani insiden keamanan informasi seperti serangan siber, bencana alam, atau kegagalan sistem.

Contoh:

1. Organisasi harus memiliki cadangan data (backup) yang disimpan di lokasi terpisah.
2. Jika terjadi serangan ransomware, sistem harus segera dikarantina dan dilaporkan ke tim IT.





Contoh | **Implementasi Kebijakan** **Keamanan Informasi** **dalam Organisasi**

Contoh 1: Perusahaan Teknologi



Situasi:

Sebuah perusahaan IT memiliki banyak data pelanggan yang sensitif dan ingin melindunginya dari kebocoran data.

Kebijakan:

1. Menerapkan autentikasi dua faktor (2FA) untuk semua karyawan.
2. Mengenkripsi semua data pelanggan sebelum disimpan di server.
3. Membatasi akses hanya kepada karyawan yang berwenang menggunakan sistem berbasis peran (Role-Based Access Control - RBAC).

Hasil:

1. Data pelanggan tetap aman dari akses yang tidak sah.
2. Risiko kebocoran data berkurang secara signifikan.

Contoh 2: Institusi Keuangan



Situasi:

Sebuah bank ingin memastikan bahwa sistem perbankan mereka aman dari serangan peretas.

Kebijakan:

1. Menggunakan firewall dan sistem deteksi intrusi (IDS/IPS) untuk melindungi jaringan internal.
2. Mewajibkan pelanggan untuk menggunakan autentikasi berbasis OTP (One-Time Password) saat masuk ke akun mereka.
3. Melakukan audit keamanan IT secara berkala.

Hasil:

1. Serangan siber dapat dideteksi dan dicegah lebih dini.
2. Pelanggan merasa lebih aman dalam menggunakan layanan perbankan online.

Contoh 3: Rumah Sakit



Situasi:

Sebuah rumah sakit ingin memastikan bahwa data pasien mereka tidak jatuh ke tangan yang salah.

Kebijakan:

1. Menggunakan sistem manajemen akses berbasis ID karyawan untuk mengakses rekam medis pasien.
2. Memastikan semua perangkat yang menyimpan data pasien dienkripsi.
3. Melarang penggunaan perangkat USB untuk mengunduh atau mentransfer data pasien.

Hasil:

1. Rekam medis pasien tetap terjaga kerahasiaannya.
2. Risiko pencurian data pasien berkurang.

Jangan lupa presensi dulu.....



**SIDOSEN ITN**
Sistem Informasi Akademik Mahasiswa Institut Teknologi Nasional Malang

AKSES NILAI MAHASISWA DAN ABSENSI LEBIH MUDAH

Our services:

- ✓ Presensi
- ✓ Absensi
- ✓ Nilai
- ✓ Absensi

Contact Us : 088026124924

1178

Sign In

Dev. by SIM-ITN Malang, Copyright. 2018

PRESENSI PERKULIAHAN KELAS (2025 GENAP)

Mata Kuliah	PSIS - KEAMANAN INFORMASI
Kelas	Kelas A
Portemon	1
Materi	Manajemen Risiko Keamanan Informasi
Tanggal	28 April 2025
Jam Mulai	10:33 AM
Jam Berakhir	10:33 AM
Ruang Kelas	RL3.2
Keterangan	
Pengisian Kelas	Dikun Terpenuhi
	<button>Submit</button>



Manfaat Penerapan Kebijakan Keamanan Informasi

1. Meningkatkan kepercayaan pelanggan
2. Melindungi reputasi organisasi
3. Mematuhi regulasi dan hukum yang berlaku
4. Mengurangi kerugian finansial akibat insiden keamanan
5. Meningkatkan kesadaran keamanan di kalangan karyawan

1. Meningkatkan Kepercayaan Pelanggan



Ketika organisasi memiliki kebijakan keamanan informasi yang jelas dan diterapkan dengan baik, pelanggan akan merasa data mereka aman. Misalnya, data pribadi, transaksi, atau informasi sensitif tidak mudah bocor atau disalahgunakan.

Kepercayaan ini sangat penting, terutama di era digital, karena pelanggan cenderung memilih layanan yang mampu menjaga privasi dan keamanan data mereka.

2. Melindungi Reputasi Organisasi



Reputasi adalah aset yang sangat berharga. Jika terjadi kebocoran data atau serangan siber, nama baik organisasi bisa rusak dalam waktu singkat.

Dengan kebijakan keamanan informasi, organisasi dapat mencegah insiden tersebut atau menanganinya dengan cepat sehingga dampaknya tidak meluas. Reputasi yang terjaga akan membuat organisasi tetap dipercaya oleh pelanggan dan mitra bisnis.

3. Mematuhi Regulasi dan Hukum yang Berlaku



Banyak negara memiliki aturan terkait perlindungan data, seperti General Data Protection Regulation (GDPR) di Eropa. Di Indonesia, terdapat regulasi seperti Undang-Undang Perlindungan Data Pribadi (UU PDP).

Dengan menerapkan kebijakan keamanan informasi, organisasi dapat memastikan bahwa mereka mematuhi hukum yang berlaku dan terhindar dari sanksi atau denda akibat pelanggaran.

4. Mengurangi Kerugian Finansial Akibat Insiden Keamanan



Insiden keamanan seperti peretasan, pencurian data, atau serangan malware dapat menyebabkan kerugian besar, baik secara langsung (misalnya kehilangan data atau uang) maupun tidak langsung (biaya pemulihan sistem, denda, dan kehilangan pelanggan).



Kebijakan keamanan membantu mencegah insiden tersebut dan meminimalkan dampaknya, sehingga organisasi dapat menghemat biaya dan menjaga stabilitas keuangan.

5. Meningkatkan Kesadaran Keamanan di Kalangan Karyawan



Karyawan sering menjadi titik lemah dalam keamanan informasi, misalnya karena menggunakan password lemah atau tidak sadar terhadap phishing.



Dengan adanya kebijakan keamanan, karyawan mendapatkan pedoman yang jelas tentang cara bekerja secara aman. Ditambah dengan pelatihan rutin, kesadaran mereka terhadap pentingnya keamanan informasi akan meningkat, sehingga risiko kesalahan manusia dapat dikurangi.

Kesimpulan



Kebijakan **keamanan** informasi sangat penting untuk melindungi data dan sistem organisasi dari berbagai ancaman. Dengan **menerapkan** kebijakan yang tepat, organisasi dapat menjaga kerahasiaan, integritas, dan ketersediaan informasi, serta memastikan kepatuhan terhadap regulasi yang berlaku.



Penerapan kebijakan yang efektif tidak hanya melibatkan teknologi tetapi juga budaya keamanan di dalam organisasi.

Quote hari ini...

Violations of information security policies can bring losses not only in **wealth**, but also in **trust** and name — and even **summon** the **shadow** of law. **Therefore**, let every user read with care, understand with clarity, and walk **faithfully** within these rules.

Pelanggaran terhadap kebijakan keamanan informasi dapat mengakibatkan kerugian finansial, reputasi, dan potensi masalah hukum. Oleh karena itu, semua pengguna harus memahami dan mematuhi kebijakan ini....



Ken Rudy

Daftar Pustaka

1. ISO/IEC. (2018). *ISO/IEC 27001:2018 - Information Security Management Systems – Requirements*. International Organization for Standardization.
2. ISO/IEC. (2018). *ISO/IEC 31000:2018 - Risk Management – Guidelines*. International Organization for Standardization.
3. Whitman, M. E., & Mattord, H. J. (2022). *Principles of Information Security* (7th ed.). Cengage Learning.
4. Peltier, T. R. (2016). *Information Security Risk Analysis* (3rd ed.). Auerbach Publications.
5. Raggad, B. G. (2010). *Information Security Management: Concepts and Practice*. CRC Press.
6. Stoneburner, G., Goguen, A., & Feringa, A. (2002). *Risk Management Guide for Information Technology Systems* (NIST SP 800-30). National Institute of Standards and Technology.
7. Calder, A. (2018). *IT Governance: An International Guide to Data Security and ISO27001/ISO27002* (6th ed.). Kogan Page.
8. Von Solms, B., & Van Niekerk, J. (2013). *Information Security: A Strategic Approach*. Springer.
9. Tipton, H. F., & Krause, M. (2007). *Information Security Management Handbook* (6th ed.). Auerbach Publications.
10. Harris, S. (2019). *CISSP All-in-One Exam Guide* (8th ed.). McGraw-Hill Education.
11. Bayuk, J. L. (2012). *Cybersecurity Policy Guidebook*. Wiley.
12. Gordon, L. A., Loeb, M. P., & Zhou, L. (2011). *The Impact of Information Security Breaches: Has There Been a Downward Shift in Costs?* *Journal of Computer Security*, 19(1), 33–56.
13. Smith, R. E. (2014). *Elementary Information Security*. Jones & Bartlett Learning.
14. ENISA. (2021). *Threat Landscape Report*. European Union Agency for Cybersecurity.
15. Bayuk, J. L., Healey, J., Rohmeyer, P., Sachs, M., & Schmidt, J. M. (2012). *Cybersecurity for Executives: A Practical Guide*. Wiley.
16. Pfleeger, C. P., & Pfleeger, S. L. (2012). *Security in Computing* (5th ed.). Prentice Hall.
17. Dhillon, G. (2007). *Principles of Information Systems Security: Text and Cases*. Wiley.
18. Sari, R. F. (2020). *Manajemen Risiko dan Keamanan Informasi dalam Organisasi Modern*. Jakarta: Prenadamedia Group.
19. Susanto, H., Almunawar, M. N., & Tuan, Y. C. (2011). *Information Security Management System Standards: A Comparative Study of the Big Five*. *International Journal of Electrical & Computer Sciences*, 11(5), 23–29.
20. BSI Group. (2017). *BS 7799-3:2017 - Information Security Management Systems - Guidelines for Information Security Risk Management*. British Standards Institution.